SYSTEM ARCHITECTURE · AS BUILT, 24 SEPTEMBER 2026

Anticounterfeit Med

A pilot for identifying counterfeit medicine in Bangladesh. Each package carries a QR symbol under a scratch coating. The platform signs a per-unit record with ML-DSA-65, and a consumer's official Android app checks that signature and records a first verification, which can happen only once per package. The pilot produces **PQC-signed verification records**, not a fully post-quantum secure system.

Django 5.2 + DRF · PostgreSQL 17 · Celery + Redis 7 · Next.js 15 staff portal · Flutter · Android · ML-DSA-65 (FIPS 204) · RFC 8785 JCS · Firebase App Check · Docker Compose on a VPS

01	System context	who and what talks to what
02	Deployment topology	host nginx, containers, networks
03	Backend modules	nine Django apps, shared crypto
04	Manufacturing and unit lifecycle	from token to redemption
05	Consumer verification flow	prepare, confirm, recover
06	Cryptography and trust	keys, records, label symbol
07	Invariants, testing and honest limits	what must never bend

9
Django apps in one backend

1
first redemption per unit, set by a PostgreSQL index

3,309 B
ML-DSA-65 signature

151
backend tests on real PostgreSQL

20
golden vectors (9 crypto, 11 label)

100 → 1
concurrent confirms → first redemptions

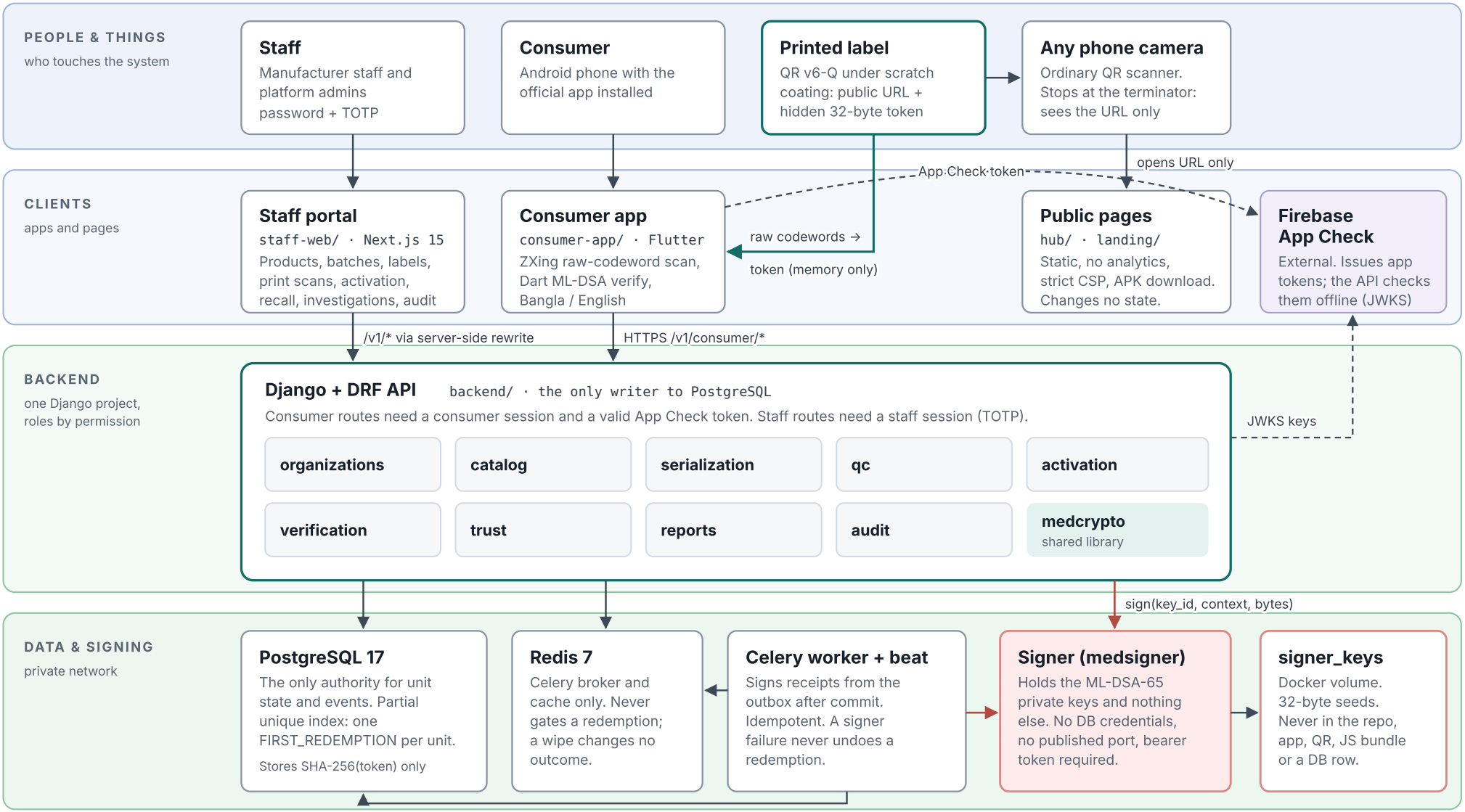
Public / clients · Edge network · Internal network · Isolated: private keys · External service

Source of truth: Medicine_Verification_Implementation_Plan.md, then docs/00–17

01 · SYSTEM CONTEXT

Who and what talks to what

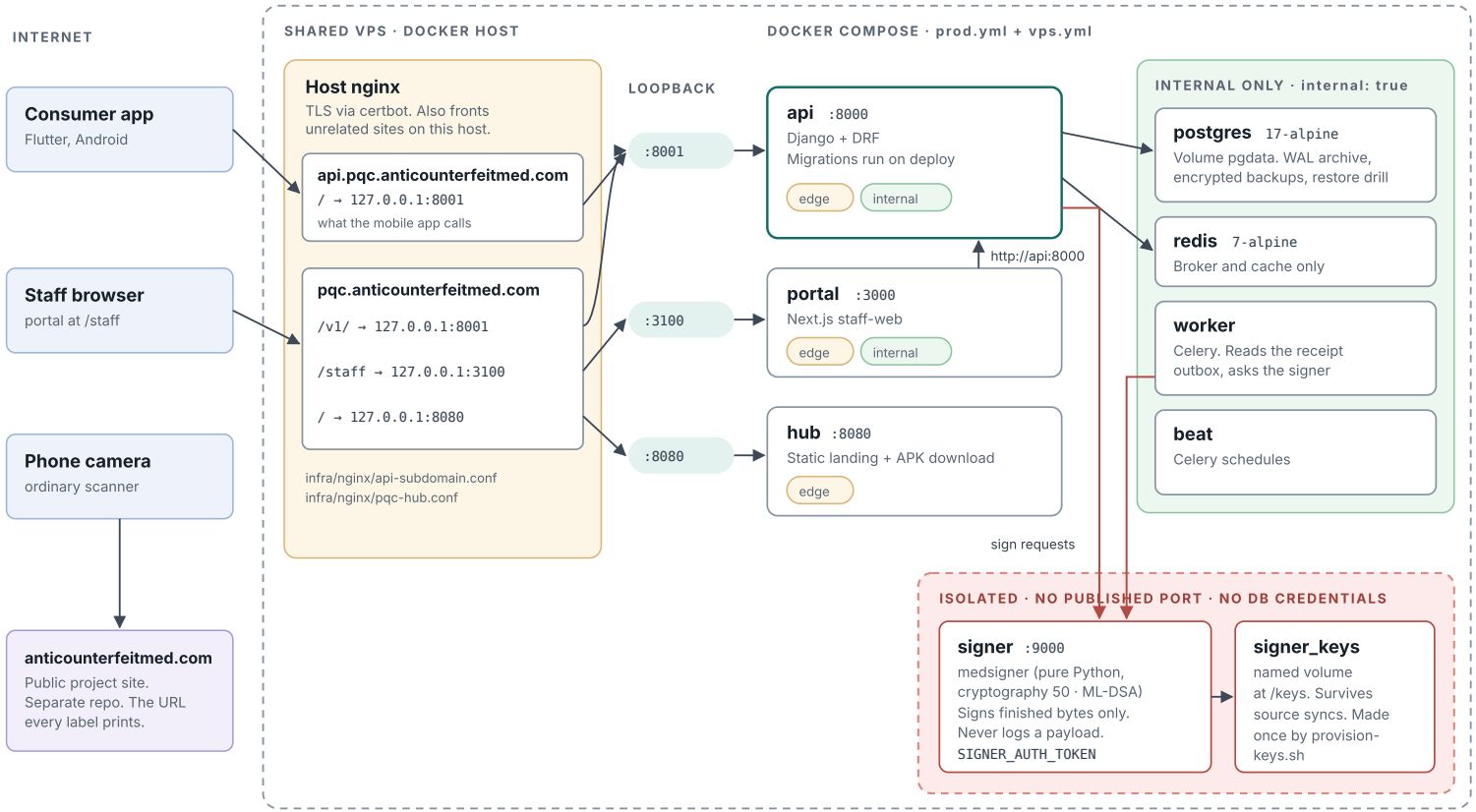
One backend serves every role. The consumer app and the staff portal are its only callers. An ordinary camera sees only the public URL and never reaches the backend. Only the API and the worker can reach the signer.



02 · DEPLOYMENT TOPOLOGY

How the pilot runs on a shared VPS

The host's nginx terminates TLS for this stack and for other sites on the same machine. The containers publish ports on 127.0.0.1 only. The `internal` network has no route out, and the signer lives only on it.



CONTAINERS

- **api**, **worker**, **beat** share one backend image.
- **portal** calls the API over the private network with server-side rewrites. The browser stays same-origin.
- **proxy** (compose nginx on 80/443) is disabled by `vps.yml` because the host nginx does that job.

SECRETS

- `infra/.env` is created on the server and never copied from a laptop. The deploy stops if it is missing.
- `provision-keys.sh` refuses to run twice, because replacing a key that has signed credentials would leave them unverifiable.

ENVIRONMENTS

- **local**: synthetic data, throwaway keys.
- **staging**: separate keys, App Check debug.
- **pilot**: real data, production keys, real attestation. Never accepts debug tokens.

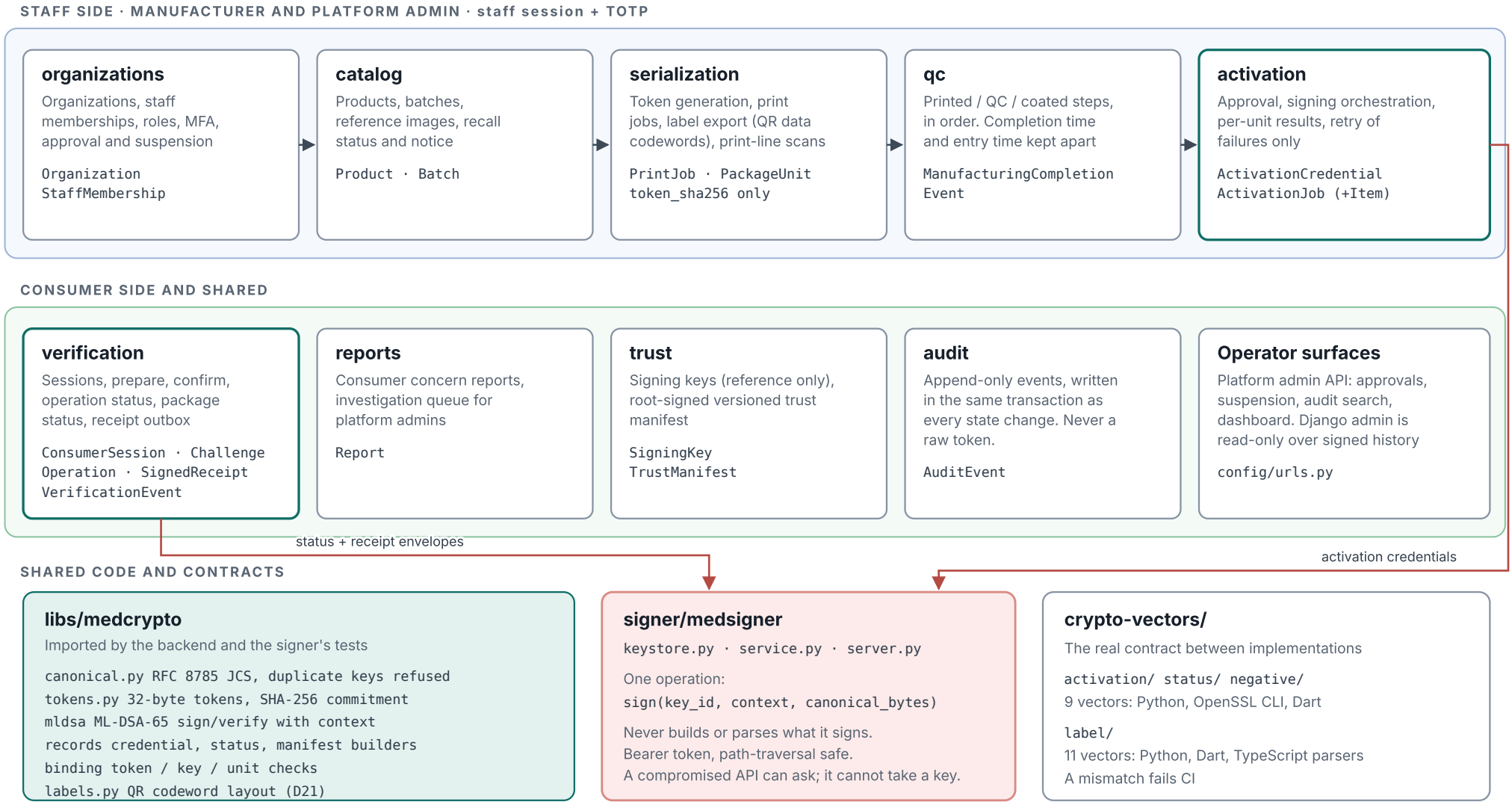
RECOVERY

- A restore must never reopen a spent code. The drill has been run: redeemed units stayed redeemed and credentials re-verified.

03 · BACKEND MODULES

Nine Django apps, one shared crypto library, one isolated signer

Apps call each other through service functions, never through another app's ORM models. Every state change writes an `AuditEvent` in the same transaction. Locks are always taken in the order organization → batch → unit. Only `verification` writes events; only `activation` writes credentials.



From a generated token to a permanent first redemption

Manufacturer staff move a batch through the portal. Every step is a state transition with its audit event. REDEEMED means a first consumer verification was committed. It is not a sale, and nothing resets it.

WHAT STAFF DO · STAFF PORTAL → STAFF API

STEP 1 · catalog
Product & batch
Brand, generic, strength, pack. Batch number, manufacture and expiry dates

STEP 2 · serialization
Print job
Random 32-byte tokens. Stores SHA-256 only. Label export returns QR data codewords, never a URL with the token

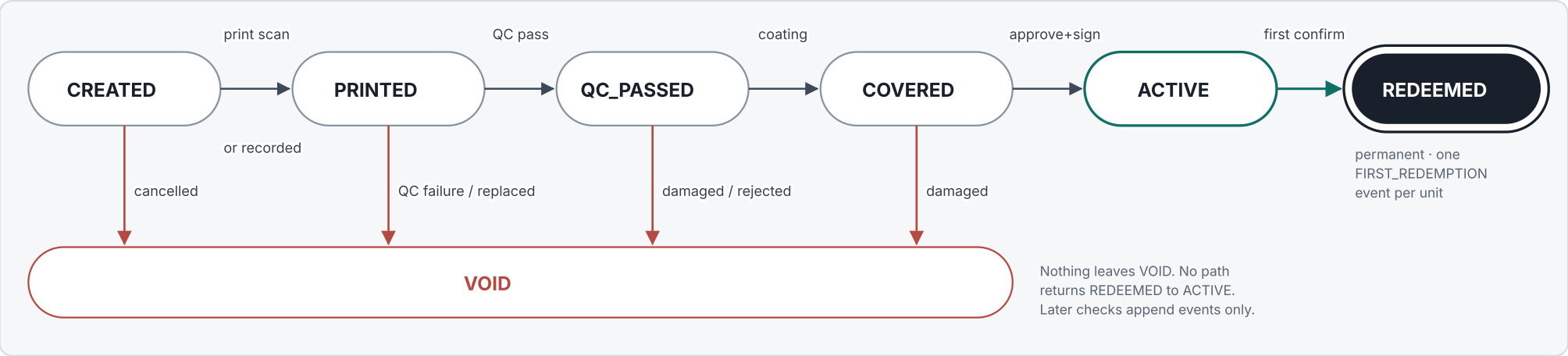
STEP 3 · print-line scan
Printed
Portal camera reads the code back. Own org only, rate-limited, CREATED only
OBSERVED

STEP 4 · qc
QC pass
Whole batch or exact unit list. Completion time + entry time
ASSERTED

STEP 5 · qc
Coating
Scratch layer covers the code, so no scan can evidence it
ASSERTED

STEP 6 · activation
Activate
Release manager approves. Signer produces one credential per unit. Partial failures reported, retry failures only

UNIT LIFECYCLE · PackageUnit.lifecycle



RESTRICTIONS · SEPARATE FIELDS, NOT STATES

Batch recall
POST /v1/batches/{id}/recall. Stops later first redemptions.

Unit block
POST /v1/units/{id}/block with an audited reason

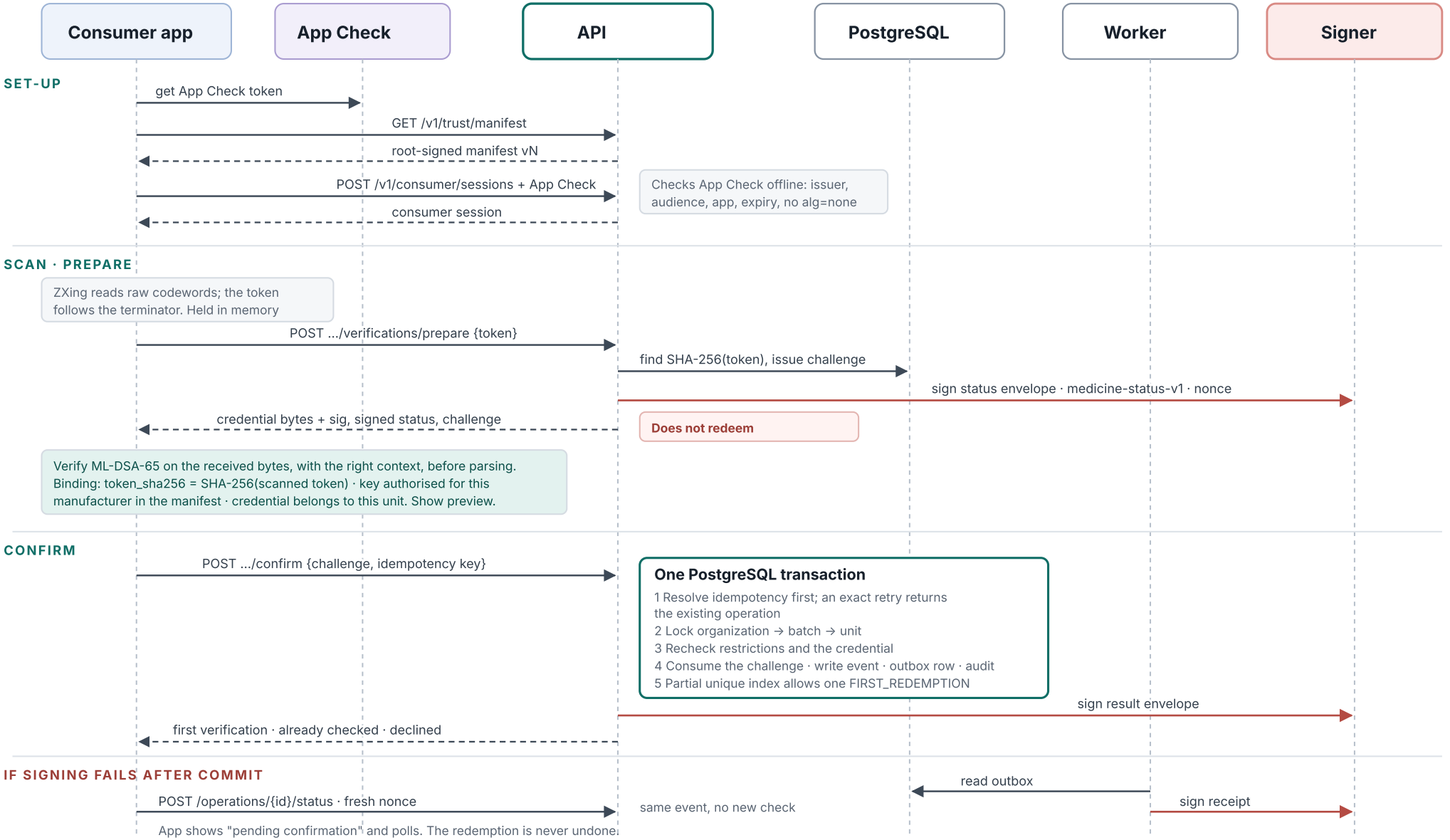
Organization suspension · key revocation
Revocation triggers a verification hold and human review

Both facts stay visible
A unit can be REDEEMED and recalled. Writers lock org → batch → unit.

05 · CONSUMER VERIFICATION FLOW

Prepare shows the package. Confirm commits once.

The app checks every signature itself, and the backend re-checks everything server-side. It never trusts the client's claim that a signature verified. GET requests, prefetches and link previews never change package state.



What is signed, by which key, and what the label carries

A valid signature alone is not enough. The verifier also checks the token commitment, that the key is authorised for the manufacturer, and that the credential belongs to the unit. In the pilot the platform holds manufacturer keys, so these are **platform-managed manufacturer-associated signatures**.

TRUST CHAIN

Offline root public key
Shipped inside the app.
Replaced only by an app update

signs

Trust manifest vN
`medicine-trust-manifest-v1`
Keys, purpose, validity, revocation. Cached up to 24 h.
No rollback to an older version

authorises

Manufacturer activation key
One per manufacturer.
Held by the platform signer

Platform status key
Status and receipt envelopes

signs

signs

SIGNED RECORDS · CONTEXT STRINGS SEPARATE THEM

Activation credential
`context: medicine-activation-v1`
Signed once at activation, immutable. Per unit:

```
key_id · manufacturer_id · package_id
token_sha256
product_snapshot{brand, generic, strength,
dosage_form, pack_description}
batch_number · manufactured_on · expires_on
qc_event_id · coating_event_id
activation_approval_id · activated_at
```

Status / result envelope
`context: medicine-status-v1`
Fresh on every response, short-lived, and signed for negative answers too:

```
package_id · token commitment
credential digest · lifecycle
restrictions · outcome · event id
request nonce · issued_at · expires_at
```

A stored receipt is history. Refresh status to know the present.

SIGN AND VERIFY

1. Build the record as JSON
2. Canonicalise: RFC 8785 JCS, duplicate keys refused
3. Signer: ML-DSA-65 with the context → 3,309 B
4. Send those exact bytes + a detached signature
5. Verify on the received bytes, then parse

Binding checks, app and backend

- ✓ signed token_sha256 = SHA-256(scanned token)
- ✓ key is authorised for this manufacturer
- ✓ credential belongs to the requested unit
- ✓ status nonce matches; response is fresh

A valid signature on another package must fail.
Public key 1,952 B · private key a 32-byte seed.
Dart verifier: pure Dart, no FFI, about 2.5 ms per verify.

LABEL SYMBOL · QR VERSION 6, ERROR CORRECTION Q · DATA CODEWORDS (D21)

`0100` byte mode	`8-bit` length	`https://anticounterfeitmed.com/` the only text any decoder reports	`0000` terminator	`"MV" 0x02` marker, version	`32 raw token bytes` raw-codeword readers only (ZXing)	`EC 11 EC 11 …` padding

Every ordinary scanner stops at the terminator and opens the public URL.

The consumer app and the portal's print-line camera read on to the token.

One layout in libs/medcrypto/medcrypto/labels.py; the Python, Dart and TypeScript parsers must agree on crypto-vectors/label/. The token is hidden from ordinary scanners, not secret: a raw-codeword decoder reads it and a photocopy still scans. The token is a possession credential; first redemption is the control.

07 · INVARIANTS, TESTING AND HONEST LIMITS

What the architecture exists to guarantee

Each invariant is enforced where it cannot be bypassed: in PostgreSQL, in the signer's isolation, or in both verifiers. None of them may change without an explicit owner decision.

1 · Raw tokens are never stored or logged
Only SHA-256(token). Raw tokens exist in the print path and in request memory. CI fails on any 43-character Base64url string in logs.

2 · REDEEMED is permanent
A PostgreSQL partial unique index allows one FIRST_REDEMPTION per unit. No API resets it. 100 concurrent confirms produce exactly one.

3 · Reads never change state
GET, HEAD, prefetches, crawlers and link previews are safe. Prepare issues a challenge and never redeems.

4 · Consumer routes need a session and App Check
A staff session never substitutes. A header, API key, CORS rule or user-agent check is not authorisation.

5 · The server re-checks every signature
The confirm transaction rechecks credential validity and restrictions under lock.

6 · Verify received bytes before parsing
Always with the correct ML-DSA context string. A signature for one context fails under another.

7 · A valid signature is not sufficient
Also check the token commitment, key-to-manufacturer authorisation, and credential-to-unit binding.

8 · Never say genuine or safe
Only that the code matches the record. Result copy is fixed in docs/09, with a mandatory clarification.

9 · PostgreSQL is the only authority
Redis is a broker and a cache. Wiping it changes no verification outcome.

10 · Private keys stay in the signer
Never in the repo, the app, the QR, the JS bundle or an ordinary database row. SigningKey stores a reference.

CI GATES

1. Lint and types: ruff, mypy, eslint, tsc, dart analyze
2. Backend tests on real PostgreSQL. SQLite would pass falsely.
3. Golden vectors: backend, signer, OpenSSL CLI, Dart, label parsers
4. Race and retry tests
5. Token-leak scan
6. Migration check

HONEST LIMITS

- Copying a QR before its first redemption is **unsolved**.
- The hidden token is hidden from ordinary scanners, not secret.
- QC pass and coating are manufacturer-asserted. Only PRINTED can be observed.
- Repeat scans and rate-limit failures are not counterfeit labels.
- Manifest freshness limits how long revocation takes to reach the app; it does not make it instant.

OUT OF SCOPE (DEFERRED BY THE SRS)

- Factory, printing and QC interfaces, except the narrow print-line scan
- Pharmacy features and sale events
- Offline redemption
- AI models
- iOS, App Links and Universal Links
- Hybrid X25519MLKEM768 TLS (next-phase experiment)